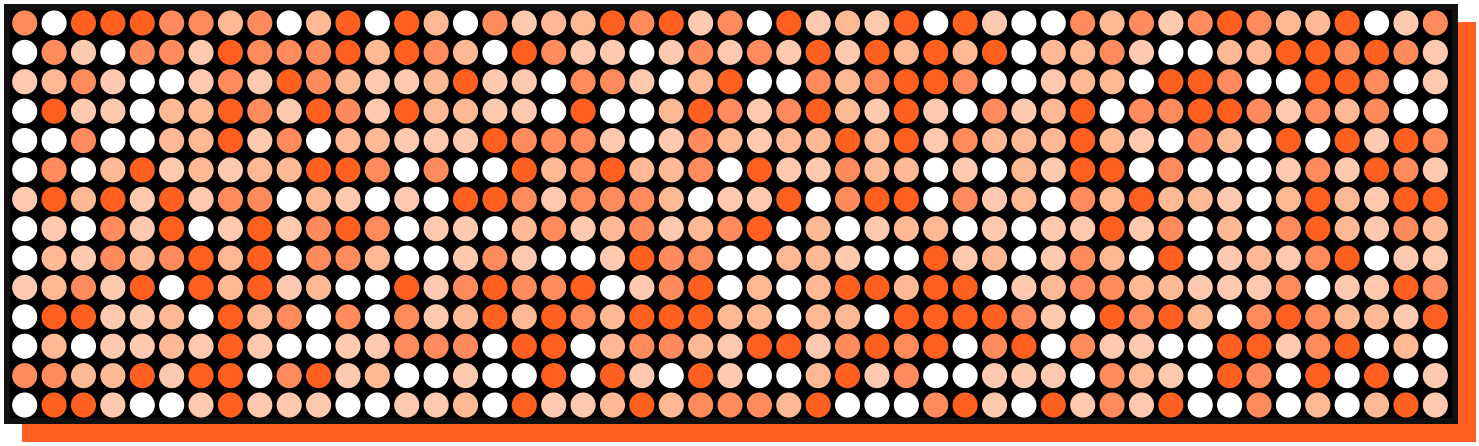
PAPYRUS EVIDENCE PACK

SECURITY CONTROLS MATRIX

Authentication, RBAC, encryption, isolation, auditing, secrets handling and known gaps, mapped to NIST SP 800-53 Rev. 5.



RELEASE	BUILT
0.1.0+fd55e38	**2026-10-20T13:03:06Z**
IMAGE	INDEX DIGEST
ghcr.io/beaglabs/papyrus/papyrus	**sha256:b38facf4950270443ac39dc5bbaeb4ed5653341b61608526163e929a449ebd8a**

Prepared by Beag Labs from the Papyrus source and its published release image. Describes the software and the responsibilities it leaves to a deploying organization. It is not a certification, an authorization or a third-party assessment.

SECURITY CONTROLS MATRIX

How Papyrus contributes to NIST SP 800-53 Rev. 5 controls when a customer deploys it, and what remains with the deploying organization. Controls were reviewed against Papyrus source revision `4b3c439aba7e` including changes not yet released. The release image was built from `fd55e3821fda`.

18	23	1	2
IMPLEMENTED	PARTIAL	PLANNED	CUSTOMER OWNED

Reading this matrix. *Implemented* means Papyrus code enforces the behavior described; *partial* and *planned* items have an open entry in the known gaps plan. *Responsibility* shows whether Papyrus (provider), the deploying organization (customer) or both (shared) carry the control. The machine-readable form is `oscal/papyrus-component-definition.json`; source evidence paths for every row are in `papyrus-controls-matrix.xlsx`.

ACCESS CONTROL

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
AC-2 Account Management	IMPLEMENTED shared	Papyrus creates no local user accounts or passwords; every person is a Microsoft Entra identity (tenant ID and object ID) and authority comes only from the eleven declared Papyrus roles. On deployments that sign in through Beag Labs, roles live in a Papyrus role-assignment table: the consenting admin is seeded as the first System Owner, only a System Owner (never an API key) can grant or revoke roles, the last System Owner cannot be revoked, and every grant and revocation is written to an append-only event table protected by database triggers. Automation uses API keys, which are service identities with no roles that name the workflows they may run, expire after 1 to 365 days (default 90), and can be rotated or revoked with creation, rotation, revocation and last use recorded. Evidence: `apps/server/src/agent/entra-auth.ts`, `apps/server/src/agent/role-assignments.ts`, `apps/server/src/agent/http.ts`, `apps/server/src/agent/api-keys.ts`, `packages/contracts/src/index.ts` Tests: `apps/server/tests/agent-auth.test.ts`, `apps/server/tests/agent-microsoft-broker.test.ts`, `apps/server/tests/api-keys.test.ts`	Own the account lifecycle in Entra ID: identity proofing, approval of app-role assignments, periodic access review, disabling departed users, and guest policy. Review Papyrus role assignments and API keys on the organization's review cadence.
AC-3 Access Enforcement	PARTIAL provider	Every protected HTTP route authenticates the caller server-side and rejects principals that hold no Papyrus role; administrative, integration, approval, audit and owner-only operations check the specific role on the server before acting. MCP servers, imported APIs, Resource Classes and API keys are scoped to the caller's tenant, and an API key is admitted only to start runs of the workflows it names and read the runs it started. Sensitive Resource Class fields are masked except for administrators and the Class's sensitive-reader groups. Evidence: `apps/server/src/agent/http.ts`, `apps/server/src/agent/service.ts`, `apps/server/src/agent/mcp/servers.ts`, `apps/server/src/agent/mastra/runtime.ts` Tests: `apps/server/tests/agent-integrations.test.ts`, `apps/server/tests/agent-observability.test.ts`, `apps/server/tests/agent-api-keys-http.test.ts`, `apps/server/tests/agent-mcp-http.test.ts`	Assign Papyrus roles in Entra (or on the Access page for brokered deployments) according to organizational need-to-know.

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
AC-4 Information Flow Enforcement	PARTIAL shared	Papyrus enforces several fixed flow rules in code: agent workspace commands run with network access denied (Factory sidecar commands do not; see sc-39); Hosted App frames carry connect-src 'none' and reach data only through brokered, operation-specific connector grants; credentials are resolved by trusted runtime code and never passed to models, App source or workspace processes; MCP tool results are labeled as external content and truncated at 64 KiB; and public intake can write only an endpoint's allow-listed fields and never person, group or reference fields. Outbound HTTP from workflows, MCP, imported APIs and Class endpoint sends must use HTTPS to a public address unless the host is explicitly listed as internal, may not embed credentials, and never follows redirects. Evidence: `apps/server/src/agent/mastra/workflow-runtime-tools.ts`, `apps/server/src/agent/mcp/calls.ts`, `apps/server/src/agent/apps/http.ts`, `apps/server/src/agent/mastra/workspace-nono-worker.ts`, `apps/server/src/agent/classes/endpoints.ts` Tests: `apps/server/tests/workflow-http-target.test.ts`, `apps/server/tests/agent-app-runtime-boundary.test.ts`, `apps/server/tests/agent-workspace.test.ts`, `apps/server/tests/agent-class-endpoints-http.test.ts`	Set PAPYRUS_WORKFLOW_HTTP_DENYLIST and PAPYRUS_WORKFLOW_HTTP_INTERNAL_HOSTS to match the authorization boundary, and enforce egress policy at the network layer.
AC-5 Separation of Duties	PARTIAL shared	The agent can propose but cannot approve: approveProposal, denyProposal and executeAction are rejected at the agent tool layer, and approval routes require a human Entra session holding Papyrus.Action.Approve. Workflow approval steps addressed to a person or group can be answered only by that person, a member of that group, or a System Owner, never by the person who started the run. Authority-weakening policy changes, non-additive Class changes and App publications wait for a Governance principal (System Owner, or Security.Manage plus Action.Approve). Evidence: `apps/server/src/agent/mastra/tools.ts`, `apps/server/src/agent/workflow-approval.ts`, `apps/server/src/agent/policies/store.ts`, `apps/server/src/agent/service.ts` Tests: `apps/server/tests/security-invariants.test.ts`, `apps/server/tests/workflow-approval.test.ts`	Assign Papyrus.Action.Approve, Papyrus.Security.Manage and Papyrus.System.Owner to different people according to organizational separation-of-duties policy.
AC-6 Least Privilege	PARTIAL shared	Papyrus splits authority into roles (integration view and manage, security manage, action approve, audit view and system owner) and checks the narrowest one per operation; Papyrus.System.Owner implies all of them. API keys hold no roles. Customer agents receive only read tools for their configured Classes and run as the requesting person. The container runs as a non-root user, and workspace commands run with the data directory unreadable and network denied. Evidence: `packages/contracts/src/index.ts`, `apps/server/src/agent/entra-auth.ts`, `apps/server/src/agent/entra-app-setup.ts`, `Dockerfile`, `apps/server/src/agent/customer-agents/store.ts` Tests: `apps/server/tests/agent-auth.test.ts`, `apps/server/tests/agent-customer-agents.test.ts`	Grant the narrowest role that fits each person, limit System Owner assignments, and do not run the container privileged.
AC-7 Unsuccessful Logon Attempts	IMPLEMENTED shared	Papyrus accepts no passwords, so interactive logon attempts and lockout are handled by Microsoft Entra ID. For the one Papyrus-managed secret a member of the public can guess, Resource Class request links with a confirmation question lock permanently after five wrong answers. Invalid, expired, revoked and rotated API keys all receive the same 401 response. Evidence: `apps/server/src/agent/classes/requests.ts`, `apps/server/src/agent/http.ts` Tests: `apps/server/tests/agent-class-requests-webhooks.test.ts`, `apps/server/tests/agent-api-keys-http.test.ts`	Configure Entra smart lockout, Conditional Access and sign-in risk policies for the tenant.
AC-12 Session Termination	PARTIAL shared	The portal session is an HMAC-signed cookie with a one-hour lifetime whose expiry is checked server-side; after it expires the person must sign in through Entra again. Sign-out clears the cookie. On brokered deployments roles are re-read from the assignment table on every request, so revoking a person's roles ends their access on the next request. Evidence: `apps/server/src/agent/entra-auth.ts`, `apps/server/src/agent/http.ts` Tests: `apps/server/tests/agent-microsoft-broker.test.ts`	Set Entra token lifetimes and Conditional Access sign-in frequency; use boundary controls if faster revocation is required.

AUDIT AND ACCOUNTABILITY

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
AU-2 Event Logging	PARTIAL shared	Papyrus records integration lifecycle events and action-ledger decisions (proposed, approved, denied, executed) in a hash-chained event table; role grants and revocations; every MCP tool call and MCP administrative change; API key creation, rotation and revocation; policy versions and policy denials; governed change requests and approvals; and agent traces and logs in a separate observability store. Evidence: `apps/server/src/agent/database.ts`, `apps/server/src/agent/role-assignments.ts`, `apps/server/src/agent/mcp/calls.ts`, `apps/server/src/agent/mcp/tools.ts`, `apps/server/src/agent/policies/store.ts`, `apps/server/src/agent/api-keys.ts` Tests: `apps/server/tests/agent-integrations.test.ts`, `apps/server/tests/agent-mcp-stores.test.ts`	Decide which additional events the organization requires and collect Entra sign-in logs from Microsoft.
AU-3 Content of Audit Records	PARTIAL provider	Audit rows carry an ISO 8601 UTC timestamp, the actor's Entra object ID, the action, the affected integration, tool or resource, and the outcome. MCP call records add session, workflow, tool classification, approval ID, duration and a SHA-256 of the arguments; write calls keep the approved arguments, while tokens and results are never stored. Configuration events exclude secret values. Evidence: `apps/server/src/agent/database.ts`, `apps/server/src/agent/mcp/calls.ts` Tests: `apps/server/tests/agent-local-secrets.test.ts`	
AU-6 Audit Record Review, Analysis, and Reporting	PARTIAL shared	Holders of Papyrus.Audit.View can read integration and action-ledger event history, and System Owners, Audit Viewers and Security Managers can read agent traces and logs through the observability API. Evidence: `apps/server/src/agent/service.ts`, `apps/server/src/agent/http.ts` Tests: `apps/server/tests/agent-observability.test.ts`	Set review cadence, alerting and escalation, and correlate Papyrus records with Entra and host logs in the organization's monitoring system.
AU-8 Time Stamps	IMPLEMENTED shared	Papyrus writes audit timestamps as ISO 8601 UTC strings taken from the host clock. Evidence: `apps/server/src/agent/role-assignments.ts`, `apps/server/src/agent/mcp/calls.ts`	Synchronize the host clock to an authoritative time source.
AU-9 Protection of Audit Information	PARTIAL shared	Audit tables are append-only at the database layer: SQLite triggers abort UPDATE and DELETE on integration events, model events, role assignment events, MCP admin events and settled MCP call records. Integration and action-ledger events are additionally SHA-256 hash-chained, and the chain can be recomputed to detect modification. Evidence: `apps/server/src/agent/database.ts`, `apps/server/src/agent/mcp/calls.ts`, `docs/security.md` Tests: `apps/server/tests/agent-integrations.test.ts`, `apps/server/tests/agent-smoke.test.ts`	Restrict host and database-file access, protect backups, and copy audit records to independently controlled immutable storage.
AU-12 Audit Record Generation	IMPLEMENTED provider	Audit records are generated server-side at the enforcement points themselves: the proposal approval and denial paths, the single MCP call path, role assignment changes, API key management and policy enforcement. They are therefore produced the same way regardless of which client made the request. Evidence: `apps/server/src/agent/service.ts`, `apps/server/src/agent/mcp/calls.ts`, `apps/server/src/agent/policies/store.ts` Tests: `apps/server/tests/agent-integrations.test.ts`	

CONFIGURATION MANAGEMENT

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
CM-2 Baseline Configuration	PARTIAL shared	Papyrus ships one Dockerfile that builds a Wolfi-based runtime image running as a non-root user with no browser engine, plus a DoD variant that defaults to the DoD Microsoft cloud and embeds the offline license authority key. The Azure Marketplace appliance is provisioned by script: the container listens only on 127.0.0.1 behind an nginx TLS edge. Three deployment profiles (commercial, government, disconnected) set runtime posture. Evidence: `Dockerfile`, `deploy/marketplace/vm/provision.sh`, `docs/deployment.md` Tests: `apps/server/tests/agent-app-connectors.test.ts`	Document the approved deployment configuration: host OS, network, Entra registration, model endpoint, storage and the Papyrus image digest.
CM-3 Configuration Change Control	IMPLEMENTED shared	In-application changes that weaken policy, alter Classes non-additively, or publish Apps become digest-checked governed changes that apply only after a Governance principal approves them, and an approval is refused if the change's digest or expected version no longer matches. Papyrus software updates are announced by exact image digest from an allowed repository and installed only when a System Owner applies them or within an owner-configured maintenance window. Evidence: `apps/server/src/agent/policies/store.ts`, `apps/server/src/agent/updates/service.ts`, `apps/server/src/agent/apps/http.ts` Tests: `apps/server/tests/agent-policies.test.ts`, `apps/server/tests/agent-updates.test.ts`	Operate organizational change control for deployment configuration, infrastructure and when updates are applied.
CM-5 Access Restrictions for Change	IMPLEMENTED shared	Configuration endpoints require specific roles on the server: Integration.Manage for model gateways, MCP servers, imported APIs, package mirrors, browser and mainframe settings and branding; System Owner for role assignments, updates, license activation and skill approval; Governance for governed changes. Model API keys are accepted only over HTTPS from the portal origin. Evidence: `apps/server/src/agent/http.ts`, `apps/server/src/agent/policies/store.ts` Tests: `apps/server/tests/agent-local-secrets-http.test.ts`, `apps/server/tests/agent-updates.test.ts`	Control access to the host, container runtime, data directory, secret stores and deployment pipeline.
CM-6 Configuration Settings	IMPLEMENTED shared	Configuration is validated at startup and fails closed: persistent mode requires an HTTPS public origin and an Entra tenant and client ID; the development identity is accepted only in local mode; unknown profiles, national clouds and sandbox backends are rejected; TLS certificate and key must be set together; and the former license-bypass setting is refused. Once an HTTPS origin is configured, Host and X-Forwarded-Host headers cannot change OAuth redirect URIs or cookies. Evidence: `apps/server/src/agent/config.ts`, `apps/server/src/agent/azure-key-vault.ts` Tests: `apps/server/tests/agent-config-origin.test.ts`, `apps/server/tests/security-invariants.test.ts`	Choose values appropriate to the authorization boundary and verify them at deployment. In Azure Government or other national clouds, set PAPYRUS_AZURE_MANAGEMENT_ENDPOINT, PAPYRUS_AZURE_MANAGEMENT_RESOURCE, PAPYRUS_AZURE_KEYVAULT_DNS_SUFFIX and PAPYRUS_AZURE_KEYVAULT_RESOURCE; they default to Azure commercial endpoints and are not derived from PAPYRUS_ENTRA_CLOUD.
CM-7 Least Functionality	IMPLEMENTED shared	The runtime image contains no browser engine. The Papyrus agent has no general shell: native programs run only through structured executors (Python, Pandoc, LibreOffice) with fixed executables. MCP has no stdio transport. The public scheduler CRUD surface is not exposed, and removed legacy connectors read back as retired and cannot be activated or executed. The Factory sidecar that builds Apps is a separate process with its own command sandbox (see sc-39). Evidence: `Dockerfile`, `apps/server/src/agent/mastra/workspace-executors.ts`, `apps/server/src/agent/mcp/servers.ts`, `apps/server/src/agent/database.ts` Tests: `apps/server/tests/agent-app-connectors.test.ts`, `apps/server/tests/agent-workspace.test.ts`, `apps/server/tests/agent-mcp-stores.test.ts`, `apps/server/tests/agent-http.test.ts`	Expose only ports 80/443 (and SSH if needed), and disable integrations and model endpoints the organization does not use.
CM-8 System Component Inventory	PARTIAL shared	A generator produces an SPDX 2.3 SBOM of every package in the pnpm lockfile, checked for drift by the pre-commit hook, and the container workflow generates a CycloneDX SBOM of the built image. Evidence: `scripts/compliance/generate.mjs`, `compliance/sbom.spdx.json`, `.github/workflows/container.yml`	Inventory the host OS, container runtime, reverse proxy, model endpoints and other infrastructure in the boundary.

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
CM-14 Signed Components	PARTIAL shared	Release images are signed with Cosign keyless signing in GitHub Actions. On the Azure Marketplace appliance the updater runs cosign verify against a pinned signer identity and issuer before pulling an update and installs nothing if verification fails; the Marketplace image pipeline verifies the signature and build provenance of the container digest before baking it. Evidence: `deploy/marketplace/vm/papyrus-update.sh`, `deploy/marketplace/vm/provision.sh`, `.github/workflows/marketplace-vm-image.yml`, `.github/workflows/container.yml`, `deploy/azure/main.bicep` Tests: `apps/server/tests/agent-updates.test.ts`	On self-hosted deployments, verify the image signature and digest before deployment.

CONTINGENCY PLANNING

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
CP-9 System Backup	CUSTOMER customer	Papyrus keeps its state in the data directory (agent.db, mastra.db, jobs.db, observability.db, secrets.db and AgentFS) and documents which files must be backed up together and that the local master key must be backed up separately. It provides no backup tooling. Evidence: `docs/deployment.md`	Back up the data directory consistently, store the master key and Key Vault recovery separately, and test restoration.

IDENTIFICATION AND AUTHENTICATION

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
IA-2 Identification and Authentication (Organizational Users)	IMPLEMENTED shared	People authenticate only through Microsoft Entra ID. Direct sign-in uses the authorization code flow with PKCE (S256), single-use state and a nonce; ID tokens are verified against the tenant's published keys for issuer, audience (client ID or api:// form), expiry, nonce and tenant ID, and discovery metadata with an unexpected issuer is rejected. Brokered sign-in redeems a one-time handle server-to-server and accepts only an assertion signed by a configured license authority key, addressed to this deployment, matching the pending login nonce and bound tenant, and unexpired. Multi-factor and PIV/CAC requirements are enforced by Entra, not by Papyrus. Evidence: `apps/server/src/agent/entra-auth.ts`, `apps/server/src/agent/microsoft-broker.ts` Tests: `apps/server/tests/agent-microsoft-broker.test.ts`, `apps/server/tests/agent-auth-profile.test.ts`, `apps/server/tests/agent-api-keys-http.test.ts`	Require MFA or phishing-resistant authentication through Entra Conditional Access. Brokered deployments trust Beag Labs' control plane to run the Microsoft sign-in; organizations that cannot accept that should use their own app registration.
IA-4 Identifier Management	IMPLEMENTED shared	Papyrus identifies people by Entra object ID and tenant ID and creates no identifiers of its own for people. API keys receive a random 12-hex-character identifier, and each deployment has its own deployment ID. Evidence: `apps/server/src/agent/entra-auth.ts`, `apps/server/src/agent/api-keys.ts` Tests: `apps/server/tests/agent-auth.test.ts`	Manage identifier issuance and reuse policy in Entra ID.
IA-5 Authenticator Management	IMPLEMENTED shared	API key secrets are 32 random bytes, shown once with cache-control no-store, and stored only as an HMAC-SHA-256 keyed with the deployment secret, so a copied database cannot be used to call the API. Keys expire, can be rotated (the old secret stops immediately) and revoked. Integration settings reject inline passwords, tokens and keys and store only credential references, and model API keys are accepted only over HTTPS from the portal origin. The pre-commit hook scans staged changes for private keys and common token formats. Evidence: `apps/server/src/agent/api-keys.ts`, `apps/server/src/agent/service.ts`, `apps/server/src/agent/http.ts`, `scripts/hooks/secret-scan.mjs` Tests: `apps/server/tests/api-keys.test.ts`, `apps/server/tests/agent-integrations.test.ts`	Manage Entra authenticators (MFA methods, certificates, client secrets) and rotate API keys on the organization's schedule.

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
IA-8 Identification and Authentication (Non-Organizational Users)	IMPLEMENTED shared	Only tokens issued for the bound Entra tenant are accepted, so any external person must exist in that tenant (for example as a guest). The only unauthenticated routes for the public are Resource Class public forms, single-use request links and signed webhooks; each answers only for an active endpoint, accepts only that endpoint's configured fields, and cannot write person, group or reference fields. Evidence: `apps/server/src/agent/entra-auth.ts`, `apps/server/src/agent/classes/http.ts`, `apps/server/src/agent/classes/webhooks.ts` Tests: `apps/server/tests/agent-class-endpoints-http.test.ts`, `apps/server/tests/agent-class-requests-webhooks.test.ts`	Decide whether guests may be assigned Papyrus roles, and approve which Class endpoints are public.

INCIDENT RESPONSE

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
IR-4 Incident Handling	CUSTOMER customer	Papyrus provides no incident handling capability or plan. Its audit and observability records are inputs to the deploying organization's process.	Maintain and exercise an incident response plan covering the Papyrus deployment, including revoking roles, API keys and connector credentials and preserving audit databases.

RISK ASSESSMENT

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
RA-5 Vulnerability Monitoring and Scanning	PLANNED shared	Beag Labs does not currently run automated vulnerability scanning of dependencies, source code or container images in CI. The SBOMs described under cm-8 are available as scanning inputs. Evidence: `.github/workflows/container.yml`	Scan hosts, the deployed image and surrounding infrastructure with the organization's tools.

SYSTEM AND SERVICES ACQUISITION

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
SA-9 External System Services	PARTIAL shared	Connected deployments call Beag Labs services outbound only: registration, signed deployment status, brokered sign-in, staff-directory Graph tokens, analytics, and on control-plane deployments hourly agent-execution usage reports to papyrus.beaglabs.com/api/deployments/usage. Status and identity responses are accepted only when signed by a configured license authority key and addressed to this deployment, and the control plane URL must be HTTPS. Registration is skipped for the disconnected profile or when PAPYRUS_BEAGLABS_REGISTRATION=0. Other outbound services the code can call are huggingface.co (embedding model download on first use unless PAPYRUS_EMBEDDING_DOWNLOAD=0), GitHub or GitLab from the Factory when configured, public package registries for skill and session installs unless PAPYRUS_PACKAGE_PUBLIC_REGISTRIES=false or the profile is disconnected, and Sentry only when a DSN is set (with sendDefaultPii disabled). Evidence: `apps/server/src/agent/control-plane.ts`, `apps/server/src/agent/microsoft-broker.ts`, `apps/server/src/agent/provisioning-control-plane.ts`, `apps/server/src/agent/beaglabs-analytics.ts`, `apps/server/src/agent/sentry.ts`, `apps/server/src/agent/execution-usage.ts`, `scripts/embedding-model.mjs`, `apps/server/src/agent/mastra-factory/app-source.ts`, `apps/server/src/agent/http.ts` Tests: `apps/server/tests/agent-control-plane.test.ts`, `apps/server/tests/agent-beaglabs-analytics.test.ts`	Assess Beag Labs as an external service provider, or use the disconnected profile or set PAPYRUS_BEAGLABS_REGISTRATION=0 to avoid it.

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
SA-11 Developer Testing and Evaluation	PARTIAL provider	The repository has workspace-wide TypeScript type checking and a Vitest suite for the server covering identity, authorization, MCP, Resource Classes, secrets, sandboxing and approvals. CI runs type checking and a fixed subset of tests (Factory, scoped workflows, mainframe guardrails and offline evaluations), and a local pre-commit hook runs secret, contract and compliance-drift checks plus security-invariant tests when related files change. Evidence: `.github/workflows/factory-write-qualification.yml`, `scripts/hooks/precommit.mjs`, `apps/server/tests/security-invariants.test.ts`	

SYSTEM AND COMMUNICATIONS PROTECTION

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
SC-5 Denial-of-Service Protection	PARTIAL shared	Request bodies are read under fixed byte ceilings and refused with 413 beyond them; public intake, request links and lookups are rate-limited per client and per endpoint; pending sign-ins are capped; and outbound workflow requests time out after 15 seconds with bodies limited to 256 KiB. Evidence: `apps/server/src/agent/http.ts`, `apps/server/src/agent/classes/endpoints.ts`, `apps/server/src/agent/classes/http.ts` Tests: `apps/server/tests/agent-class-endpoints-http.test.ts`, `apps/server/tests/agent-http.test.ts`	Provide network-layer DoS protection and rate limiting at the reverse proxy or gateway.
SC-7 Boundary Protection	PARTIAL shared	On the Marketplace appliance the container is published only on 127.0.0.1 and reached through nginx. Every outbound call made for MCP, OAuth discovery, workflows, imported APIs and Class endpoint sends passes one check: HTTPS, no embedded credentials, an organization denylist, and refusal of hosts that resolve to loopback, private or link-local addresses (including cloud metadata) unless listed as internal; redirects are not followed. Calls to the Beag Labs control plane are outbound only. Workspace commands have no network access. Evidence: `apps/server/src/agent/mastra/workflow-runtime-tools.ts`, `apps/server/src/agent/mcp/oauth.ts`, `deploy/marketplace/vm/provision.sh`, `apps/server/src/agent/azure-key-vault.ts` Tests: `apps/server/tests/workflow-http-target.test.ts`, `apps/server/tests/agent-mcp-stores.test.ts`	Place the deployment behind the organization's firewalls and proxies, restrict inbound access to 443, and set the egress denylist and internal-host list.
SC-8 Transmission Confidentiality and Integrity	IMPLEMENTED shared	Persistent mode refuses to start without an HTTPS public origin. The daemon can terminate TLS itself with a TLS 1.2 minimum, and the Marketplace appliance's nginx edge allows only TLS 1.2 and 1.3 and sends HSTS. Portal cookies are Secure under HTTPS. Outbound connections to MCP servers, workflows, imported APIs, Class endpoints and the control plane require HTTPS except for hosts the organization explicitly lists as internal. Evidence: `apps/server/src/agent/config.ts`, `apps/server/src/agent/http.ts`, `deploy/marketplace/vm/provision.sh`, `apps/server/src/agent/control-plane.ts` Tests: `apps/server/tests/workflow-http-target.test.ts`, `apps/server/tests/agent-local-secrets-http.test.ts`	Provide certificates, TLS termination and cipher policy that meet organizational requirements.
SC-12 Cryptographic Key Establishment and Management	PARTIAL shared	The local secrets master key must be a separately provisioned 32-byte file that is not group- or world-writable and is opened without following symlinks; the server never generates it. Where Azure Key Vault is configured, the portal secret, Entra client secret and model and provider keys are kept in a deployment Key Vault (RBAC mode, purge protection, 90-day soft delete) with only the VM's managed identity granted access, and each reader is limited to its own secret-name prefix. License authority public keys are supplied by configuration or baked into the DoD image. Evidence: `apps/server/src/agent/local-secrets.ts`, `apps/server/src/agent/deployment-vault.ts`, `apps/server/src/agent/azure-key-vault.ts`, `apps/server/src/agent/openapi/credentials.ts` Tests: `apps/server/tests/agent-local-secrets.test.ts`, `apps/server/tests/agent-deployment-vault.test.ts`	Provision, back up and protect the master key and portal secret; manage Entra and TLS keys.

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
SC-13 Cryptographic Protection	PARTIAL shared	Papyrus uses the Node.js crypto module (OpenSSL) for AES-256-GCM encryption of stored credentials, HMAC-SHA-256 for cookies, API key hashes and webhook signatures, SHA-256 hash chains, SHA-256 signature verification of license, status and identity documents, and TLS; JWTs are verified with the jose library. FIPS mode is not enabled anywhere in the repository or image. Evidence: `apps/server/src/agent/local-secrets.ts`, `apps/server/src/license.ts`, `apps/server/src/agent/entra-auth.ts`, `Dockerfile`	Where FIPS 140 validated cryptography is required, run on a validated module and terminate TLS on validated infrastructure.
SC-18 Mobile Code	IMPLEMENTED provider	Agent-built Hosted App and Factory preview code runs in an opaque iframe sandboxed to allow-scripts only, with a CSP of default-src 'none', connect-src 'none', form-action 'none' and base-uri 'none', loaded through a one-use frame ticket. App source that performs direct browser networking or contains credential literals or ambient secrets is rejected before release. HTML and SVG artifacts are served as attachments with a sandbox CSP. Evidence: `apps/server/src/agent/apps/http.ts`, `apps/server/src/agent/apps/project.ts`, `apps/server/src/agent/factory-preview.ts`, `apps/server/src/agent/http.ts` Tests: `apps/server/tests/agent-app-runtime-boundary.test.ts`, `apps/server/tests/agent-app-host.test.ts`, `apps/server/tests/agent-factory-publication.test.ts`	Optionally route a separate HTTPS App origin (PAPYRUS_APP_ORIGIN) as defense in depth.
SC-23 Session Authenticity	IMPLEMENTED provider	The portal session cookie is HMAC-SHA-256 signed with the deployment secret, compared in constant time, and set HttpOnly, SameSite=Strict, Secure and with the __Host- prefix under HTTPS. OIDC state and nonce are random 32-byte values held server-side, single-use and expiring after 10 minutes; MCP OAuth sign-ins are likewise single-use, bound to the initiating person and checked against the discovered issuer. Once an HTTPS origin is configured, request headers cannot change the origin used for redirects or cookies. Evidence: `apps/server/src/agent/entra-auth.ts`, `apps/server/src/agent/mcp/oauth.ts`, `apps/server/src/agent/config.ts` Tests: `apps/server/tests/agent-mcp-runtime.test.ts`, `apps/server/tests/agent-config-origin.test.ts`, `apps/server/tests/agent-auth-profile.test.ts`	
SC-28 Protection of Information at Rest	PARTIAL shared	Papyrus encrypts secrets at the application layer with AES-256-GCM and per-record associated data: model gateway keys in a separate 0600 secrets database under a separately provisioned master key; and connector, imported-API and MCP credentials bound to their owner. Where Azure Key Vault is configured, platform secrets are stored there and configuration files hold only references. Evidence: `apps/server/src/agent/local-secrets.ts`, `apps/server/src/agent/openapi/credentials.ts`, `apps/server/src/agent/deployment-vault.ts` Tests: `apps/server/tests/agent-local-secrets.test.ts`, `apps/server/tests/agent-mcp-stores.test.ts`, `apps/server/tests/agent-deployment-vault.test.ts`	Encrypt the volume that holds the data directory and its backups, and manage those keys.
SC-39 Process Isolation	PARTIAL provider	Commands the Papyrus agent runs in its workspace run in a separate worker process under landstrip (Landlock and seccomp on Linux, Seatbelt on macOS) with writes limited to a temporary materialized workspace, the Papyrus data directory unreadable and network denied. The worker validates and resolves the effective policy before starting the command and refuses to run if the write root, network restriction or data-directory denial is not in effect; unsupported platforms run no workspace commands. Credential-like environment variables are removed before the command starts. Evidence: `apps/server/src/agent/mastra/workspace-nono-worker.ts`, `apps/server/src/agent/mastra/workspace-nono.ts`, `apps/server/src/agent/mastra/workspace-landstrip.ts`, `apps/factory/src/mastra/index.ts` Tests: `apps/server/tests/security-invariants.test.ts`, `apps/server/tests/agent-workspace.test.ts`, `apps/server/tests/agent-session-workspace.test.ts`	Run on a Linux host with Landlock enabled and do not run the container privileged.

SYSTEM AND INFORMATION INTEGRITY

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
SI-2 Flaw Remediation	PARTIAL shared	Beag Labs publishes fixes as new signed images. A deployment learns of a release through an HMAC-signed, timestamped webhook with replay protection, and a System Owner applies it or allows it to apply within a maintenance window; the Marketplace updater verifies the image signature before installing. Evidence: `apps/server/src/agent/updates/service.ts`, `deploy/marketplace/vm/papyrus-update.sh` Tests: `apps/server/tests/agent-updates.test.ts`	Set patch windows, test updates and apply them within organizational timeframes.
SI-4 System Monitoring	IMPLEMENTED shared	Papyrus records agent traces and logs in a separate observability database readable by System Owners, Audit Viewers and Security Managers, writes structured JSON warnings to standard output, and can send errors to a customer-supplied Sentry DSN. The container health check verifies that the landstrip sandbox enforces its boundary; it does not check that the HTTP service is answering. Evidence: `apps/server/src/agent/http.ts`, `apps/server/src/agent/sentry.ts`, `Dockerfile`, `deploy/container/healthcheck.mjs` Tests: `apps/server/tests/agent-observability.test.ts`	Collect container output and audit data into the organization's monitoring platform and alert on it.
SI-7 Software, Firmware, and Information Integrity	IMPLEMENTED shared	Releases are referenced by image digest and signature-verified before the Marketplace updater installs them. Hosted App publication approves an immutable, digest-checked build. Governed changes are re-hashed at approval and refused if the digest differs. The stored control-plane status is re-verified against its signature on every read, so editing the file cannot lift a suspension. Integration and action events are hash-chained. Evidence: `apps/server/src/agent/updates/service.ts`, `apps/server/src/agent/factory-publication.ts`, `apps/server/src/agent/policies/store.ts`, `apps/server/src/agent/control-plane.ts` Tests: `apps/server/tests/agent-control-plane.test.ts`, `apps/server/tests/agent-factory-publication.test.ts`, `apps/server/tests/agent-policies.test.ts`	Verify image digests and signatures on deployment paths other than the Marketplace appliance.
SI-10 Information Input Validation	IMPLEMENTED provider	Request bodies must be JSON objects under per-route byte limits; required strings are length-bounded; policy rules are validated against a fixed schema; public forms accept only allow-listed fields and bounded uploads of permitted types and cannot reference Library paths; outbound addresses are validated before use; and webhook payloads are signature-checked over the exact raw bytes. Evidence: `apps/server/src/agent/http.ts`, `apps/server/src/agent/policies/evaluator.ts`, `apps/server/src/agent/classes/endpoints.ts` Tests: `apps/server/tests/agent-policies.test.ts`, `apps/server/tests/agent-class-endpoints-http.test.ts`, `apps/server/tests/agent-http.test.ts`	
SI-11 Error Handling	PARTIAL shared	Errors are returned as JSON with a code and a per-request ID. Known error types map to specific status codes, sign-in error pages do not echo request input, the browser connection address is masked in error text, and imported-API credentials are redacted from errors. Evidence: `apps/server/src/agent/http.ts` Tests: `apps/server/tests/agent-mcp-http.test.ts`	Configure log handling so diagnostic output is not exposed beyond administrators.

SUPPLY CHAIN RISK MANAGEMENT

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
SR-4 Provenance	PARTIAL shared	Container images built from main are signed with Cosign and receive a GitHub build provenance attestation. Dependencies are locked in pnpm-lock.yaml and installed with --frozen-lockfile in CI, and the pnpm version is pinned with a hash in packageManager. Evidence: `.github/workflows/container.yml`, `pnpm-lock.yaml`, `package.json`, `.github/workflows/factory-write-qualification.yml`	Retain the image digests and attestations for deployed releases and verify them at intake.